

THRESHOLD ENTERPRISE SYSTEMS

Security Incident Response Policy

Document Id	SEC-004
Title	Security Incident Response Policy
Department	Information Security
Classification	CONFIDENTIAL
Version	1.0
Status	ACTIVE
Effective Date	2026-01-15
Document Type	PROCEDURE
Allowed Roles	SECURITY_ENGINEER, MANAGER, ADMIN

1. CONFIDENTIAL CLASSIFICATION AND OPERATIONAL OBJECTIVES

*** CONFIDENTIAL DOCUMENT - RESTRICTED OPERATIONAL PROCEDURE ***

This document contains proprietary incident response workflows, containment playbooks, forensic handling protocols, severity classification criteria, and executive escalation trees for Threshold Enterprise Systems. It is classified as CONFIDENTIAL. Access is restricted to authorized roles (SECURITY_ENGINEER, MANAGER, ADMIN). Standard workforce members holding the EMPLOYEE role are not permitted to access this operational procedure in the knowledge base.

The primary objectives of this Security Incident Response Policy and Standard Operating Procedure are: to establish a coordinated, rapid, and structured capability to detect, analyze, contain, eradicate, and recover from cybersecurity incidents; to minimize operational disruption and financial loss; to protect client and proprietary data assets; to preserve digital evidence; and to meet statutory breach disclosure mandates across our global jurisdictions.

2. CRITICAL DISTINCTION: CYBERSECURITY INCIDENT VS. WORKPLACE INCIDENT

*** MANDATORY SCOPE CLARIFICATION: CYBERSECURITY VS. PHYSICAL WORKPLACE INCIDENTS ***

It is essential that all management and engineering staff maintain a clear operational distinction between Cybersecurity Incidents and Workplace Incidents:

A Cybersecurity Incident (governed exclusively by this document, SEC-004) is defined as any confirmed or suspected event that compromises the confidentiality, integrity, availability, or authenticity of enterprise digital assets, electronic communications, cloud infrastructure, customer databases, or proprietary algorithms.

A Workplace Incident (governed separately by Human Resources under HR-008: Workplace Incident Reporting Policy) encompasses physical safety hazards, slips, trips, falls, occupational medical emergencies, workplace violence, behavioral harassment, discrimination, or physical facility property damage.

THE HR WORKPLACE INCIDENT REPORTING POLICY (HR-008) MUST NEVER BE TREATED AS OR SUBSTITUTED FOR CYBERSECURITY INCIDENT RESPONSE PROCEDURES. If an incident involves both domains (e.g., physical theft of a laptop containing confidential data), reporting must occur concurrently to both HR/Facilities and the Information Security Operations Center (ISOC).

3. Incident Severity Classification Framework

To ensure rapid, proportional mobilization of resources, cybersecurity incidents are categorized into four standardized severity tiers upon initial triage:

- Severity Level 1 - Critical Incident (P1): Active systemic compromise of production cloud environments; widespread ransomware infection; unauthorized exfiltration of RESTRICTED or CONFIDENTIAL customer databases; complete outage of customer-facing AI platforms; or active nation-state adversary infiltration. Requires 24/7 war room activation, executive notification within 30 minutes, and technical response mobilization within 15 minutes.
- Severity Level 2 - Major Incident (P2): Significant unauthorized access to sensitive internal systems; compromise of elevated administrator credentials without confirmed data exfiltration; high-volume DDoS attacks causing partial service degradation; or critical zero-day vulnerabilities actively exploited in enterprise dependencies. Requires technical response mobilization within 60 minutes.
- Severity Level 3 - Moderate Incident (P3): Isolated endpoint malware infections contained by EDR software; localized credential phishing incidents without privilege elevation; minor policy violations; or vulnerability scanning probes. Managed during business hours with initial analysis completed within 4 hours.
- Severity Level 4 - Minor Security Event (P4): Low-risk automated alerts, false-positive alerts, single-user account lockouts, or routine security anomalies requiring informational logging. Addressed within standard 24-hour operational ticketing SLAs.

4. Detection, Reporting, and Initial Intake Mechanisms

Cybersecurity incidents are detected through multiple proactive and reactive intake channels:

1. Automated Threat Detection: Real-time SIEM alerts, Endpoint Detection and Response (EDR) telemetry, Cloud Security Posture Management (CSPM) anomalies, Web Application Firewall (WAF) triggers, and automated network intrusion prevention alarms.
2. Workforce Reporting: Any employee observing suspicious digital activity, unexpected MFA prompts, or phishing attempts submits an urgent ticket to security-incident@threshold-systems.internal or calls the 24/7 ISOC emergency hotline at ext. #7777.
3. External Threat Intelligence and Responsible Disclosures: Notifications from external security researchers, vulnerability disclosure programs (VDP), law enforcement agencies, or national CERT advisories (e.g. CERT-In, CISA, NCSC).

Upon intake, the on-duty ISOC Tier 2 Analyst logs an Incident Record in the Security Orchestration, Automation, and Response (SOAR) platform, timestamps the alert, and executes initial validation.

5. Incident Triage and Incident Commander Assignment

During initial triage, the lead analyst assesses threat validity, determines preliminary severity (P1-P4), and establishes an Incident Response Docket.

For all P1 (Critical) and P2 (Major) incidents, a certified Lead Security Engineer is immediately designated as the 'Incident Commander' (IC). The IC assumes complete operational authority over technical containment, resource mobilization, and inter-departmental coordination.

The Incident Commander activates the Computer Security Incident Response Team (CSIRT), comprising: Technical Lead, Digital Forensics Specialist, Infrastructure/Cloud Engineer, Legal Counsel, Communications Lead, and HR Liaison.

6. Containment Strategies and Tactical Isolation

Containment prevents an intrusion from spreading laterally across enterprise networks, exfiltrating data, or causing collateral damage. Containment is executed in two structured phases:

Short-Term Containment: Immediate actions executed within minutes of verification to halt ongoing threat activity. Tactics include: isolating affected virtual machines or endpoints from the network via EDR network containment; revoking compromised SSO sessions and rotating credentials; blocking malicious IP addresses and domains at the edge firewall;

and disabling compromised service principals.

Long-Term Containment: Actions taken to stabilize the environment while preserving evidence for forensic analysis. Tactics include: establishing clean, segmented sandbox networks; applying temporary firewall filtering rules; snapshotting volatile virtual machine memory; and deploying enhanced monitoring probes across adjacent infrastructure tiers.

7. Digital Forensics, Evidence Preservation, and Investigation

Once containment is secured, forensic investigators determine the root cause, scope of compromise, threat actor tactics, techniques, and procedures (TTPs), and whether data exfiltration occurred.

Forensic Integrity and Chain of Custody: Investigators must follow strict forensic protocols adhering to ISO/IEC 27037 standards. Volatile memory (RAM) must be captured prior to rebooting or powering down systems. Bit-stream disk images must be generated using cryptographic write-blockers. All forensic images must be verified against SHA-256 cryptographic hashes and cataloged in a physical or digital Chain of Custody Log.

Root Cause Analysis: Analysts examine system event logs, firewall telemetry, web proxy records, cloud audit trails, and memory dumps to reconstruct the complete attack kill chain according to the MITRE ATT&CK framework.

8. Eradication, Hardening, and System Recovery

Eradication eliminates all traces of the threat actor and malware from the environment, while recovery safely restores systems to full operational status.

Eradication Actions: Deleting malicious binaries, scripts, and backdoors; closing unauthorized persistence mechanisms (scheduled tasks, registry keys, hidden accounts); revoking and re-issuing all administrative cryptographic keys, certificates, and secrets; and patching underlying software vulnerabilities.

Recovery and Validation: Rebuilding affected systems from known-clean golden machine images or verified backups; restoring validated configuration parameters; re-establishing network connectivity under enhanced monitoring; and performing active vulnerability scanning and penetration testing to verify remediation.

Phased Restoration: Production services are brought online in controlled phases, validating functionality, performance, and security telemetry before declaring operational restoration.

9. Post-Incident Review (PIR) and Continuous Improvement

Within seven (7) business days of declaring incident resolution for any P1 or P2 incident, the Incident Commander convenes a mandatory Post-Incident Review (PIR) meeting with all CSIRT participants, engineering leads, and departmental leadership.

The PIR examines the complete chronological timeline, evaluates what worked effectively, identifies communication or technical bottlenecks, and determines root cause deficiencies.

The findings are synthesized into a formal Post-Incident Review Report, detailing: executive summary, incident timeline, technical root cause, business impact metrics, and a prioritized Corrective and Preventative Actions (CAPA) tracking matrix. CAPA items are assigned to engineering owners with strict remediation SLAs and tracked to completion by the Information Security GRC team.

10. Communications, Regulatory Reporting, and Legal Coordination

External communications regarding cybersecurity incidents are strictly managed to protect client confidentiality, preserve legal privilege, and comply with international disclosure mandates.

Under no circumstances may any employee discuss active security incidents with external parties, journalists, or on personal social media channels without explicit written authorization from the Chief Legal Officer and Corporate Communications Director.

Regulatory Disclosure Mandates: When an incident involves unauthorized access to personal data, our Legal and Privacy teams coordinate mandatory statutory notifications within strict jurisdictional timelines:

- European Union / United Kingdom GDPR: Formal notification to the relevant Data Protection Authority (e.g. UK ICO) within seventy-two (72) hours of becoming aware of a personal data breach.
- United States: Notification to affected individuals, state Attorneys General, and regulatory bodies (e.g. SEC for material events) within applicable federal and state statutory deadlines.
- India / Singapore: Notification to the Indian Computer Emergency Response Team (CERT-In) within prescribed statutory windows (6 hours for specified critical incidents) and the Singapore Personal Data Protection Commission (PDPC) within three (3) calendar days.